

27/7/2020

Liability Analysis in Ethical Hacking

1) Introduction

Ethical hacking involves testing computer systems with proper authorization to identify security vulnerabilities. In this scenario, the contract only stated "test the network," making the scope unclear. The ethical hacker tested a cloud service.

2) Liability Analysis

A) Ethical Hacker

The ethical hacker may be liable because:

- Tested systems outside the agreed scope
- Failed to confirm ownership of the cloud service.
- Accessed third-party systems without permission.
- Could face legal action for unauthorized access.
- May lose professional credibility.

B) Client Organization

The client may also share responsibility because:

- The contract used vague wording
- Failed to clearly define testing boundaries
- Did not mention third-party cloud services
- Failed to obtain permissions from cloud provider.

C) Third Party Provider

- Their systems were tested without authorization
- Unauthorized testing may violate service agreements + laws

- Did not mention third-party cloud services.
- Failed to obtain permission from the cloud providers.

c) Importance of proper Scoping

- Systems included in testing
- Systems excluded from testing.
- IP addresses and domains
- Cloud services covered.
- Testing duration

3. Third Party Provider

The third party has the right to take legal action:

- Their systems were tested without authorization.
- Unauthorized testing may violate service agreements and cybersecurity laws.
- They may claim damages if their services were affected.

Benefits

- Prevents misunderstandings.
- Keeps testing within legal boundaries.
- Protects both the clients and the ethical hacker.

4) Importance of Legal Documentation

State of work.

- Defines objectives - scope, timeline, and deliverables.
- Rules of engagement (ROE)
 - > Explains how testing should be conducted.
 - > Lists allowed and prohibited activities.

Authorization letter.

- gives written permission to perform
- Specifies the system that can be tested.

NDA:

- Protects confidential information

6) Conclusion:

The ethical hacker may be responsible for exceeding the authorized scope, while the client also shares responsibility for providing an authorized scope.